TP CGI

I) Introduction à l'Identity and Access Management (IAM)

Dans cette introduction, nous allons aborder les concepts clés de l'Identity and Access Management (IAM). L'IAM est un ensemble de pratiques et de technologies permettant de gérer le cycle de vie des identités, l'identification, l'authentification et l'autorisation des utilisateurs dans un système informatique.

- **Gestion du cycle de vie des identités** : L'IAM (Identity and Access Management) ne se limite pas à la simple création de comptes. Il englobe la gestion intégrale du cycle de vie des identités des utilisateurs. Cela commence par la création de l'identité, inclut les modifications, les mises à jour, les absences temporaires, les départs d'urgence, et se termine par la suppression du compte ou de l'identité lorsque cela est nécessaire.
- **Access Management (gestion des accès) :** L'Access Management gère les politiques et les règles qui contrôlent l'accès aux ressources et aux fonctionnalités du système. Il garantit que les utilisateurs ont uniquement accès aux ressources autorisées en fonction de leurs autorisations.
- **Identification** : Dans le cadre de l'IAM (Identity and Access Management), l'identification fait référence à l'attribution d'une identité numérique unique à une personne. Cette identité peut être associée à plusieurs comptes applicatifs selon les besoins de l'individu. Elle permet de reconnaître de manière unique un utilisateur dans le système, que ce soit par le biais d'un nom d'utilisateur, d'une adresse e-mail, ou tout autre identifiant choisi.
- **Authentification** : Une fois l'identité d'un utilisateur établie, l'authentification permet de vérifier que l'utilisateur est bien la personne qu'il prétend être. Cela peut impliquer la saisie d'un mot de passe, l'utilisation d'un certificat numérique,ou d'autres mécanismes de vérification.
- **Autorisation** : Une fois qu'un utilisateur est authentifié, l'autorisation détermine les actions et les ressources auxquelles cet utilisateur est autorisé à accéder. Les autorisations sont généralement basées sur des rôles, des groupes ou des politiques définies par les administrateurs du système

- **Fédération d'identités** : La fédération d'identités permet aux utilisateurs d'utiliser le même identifiant et mot de passe pour accéder à des ressources réparties sur plusieurs domaines ou organisations distinctes. Cela facilite les collaborations inter-entreprises. De plus, la fédération permet également la création de comptes en héritant des droits et des attributs d'un autre compte applicatif, offrant ainsi une flexibilité et une efficacité accrues dans la gestion des accès.

II) Composants de l'IAM

Nous allons à présent nous concentrer sur les principaux composants de l'IAM et leur rôle dans la gestion des identités et des accès.

- **Identity Provider (fournisseur d'identité) :** Un Identity Provider est un service qui émet et vérifie les informations d'identité des utilisateurs. Il permet aux utilisateurs de s'authentifier auprès de différents services et applications qui y sont raccordés en utilisant un seul ensemble d'informations d'identification.
- **Référentiel (répertoire d'utilisateurs) :** Le référentiel est une base de données qui stocke les informations relatives aux utilisateurs et/ou à leurs droits, telles que leurs identifiants, leurs attributs et leurs autorisations. Cela peut inclure des informations telles que les noms d'utilisateur, les adresses e-mail, les mots de passe chiffrés, etc. Bien que le référentiel soit souvent considéré comme détenant la vérité sur son domaine, il est important de noter que la source d'informations peut parfois être tierce, comme une solution SIRH ou un autre système externe. Dans de tels cas, le référentiel agit comme un agrégateur ou un point de synchronisation pour ces informations.
- **Provisioning :** Le provisioning désigne l'ensemble des actions de création, de modification et de suppression des comptes et des accès en fonction des événements du cycle de vie des utilisateurs, comme l'arrivée d'un nouvel employé dans l'entreprise. Ces actions peuvent être réalisées de manière automatique ou manuelle, selon les besoins et les configurations de l'organisation. Elles peuvent cibler aussi bien des applications spécifiques que le référentiel principal d'utilisateurs.
- **Révocation :** La révocation est le processus complémentaire du provisioning. Elle concerne le retrait ou l'annulation d'un accès ou d'un rôle précédemment accordé, que ce soit en raison du départ d'un utilisateur de l'organisation, d'un changement de rôle ou pour d'autres raisons pertinentes

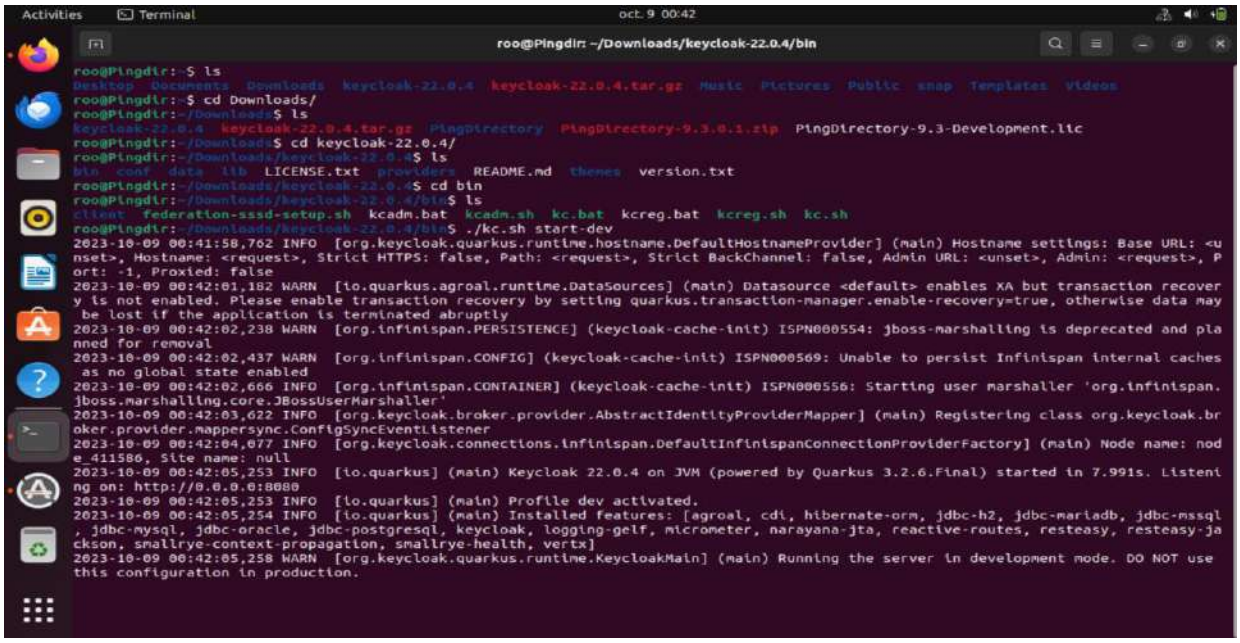
- **RBAC** : La gestion basée sur les rôles (RBAC) est une approche pour définir et attribuer des droits d'accès en fonction des rôles au sein de l'organisation. Par exemple, un rôle "comptable" peut avoir accès à certaines applications financières que d'autres rôles n'ont pas.
- **Multi-Factor Authentication (MFA) :** La MFA est une méthode d'authentification qui nécessite la validation de deux ou plusieurs facteurs d'authentification. Cela peut inclure quelque chose que l'utilisateur sait (mot de passe), quelque chose que l'utilisateur possède (carte à puce, token) ou quelque chose que l'utilisateur est (empreinte digitale, reconnaissance faciale).
- **Single Sign-On** (authentification unique) : Le Single Sign-On permet aux utilisateurs de s'authentifier une seule fois et d'accéder à plusieurs applications raccordées à ce SSO sans avoir à se reconnecter à chaque fois. Cela améliore l'expérience utilisateuret simplifie la gestion des identifiants.

Exercice 1 : Installation et configuration de Keycloak (Identity Provider)

Dans cet exercice, nous allons configurer Keycloak, un Identity Provider open source largement utilisé. Keycloak permet de centraliser la gestion des identités et des accès dans un environnement IAM.

1. Déploiement du serveur Keycloak :

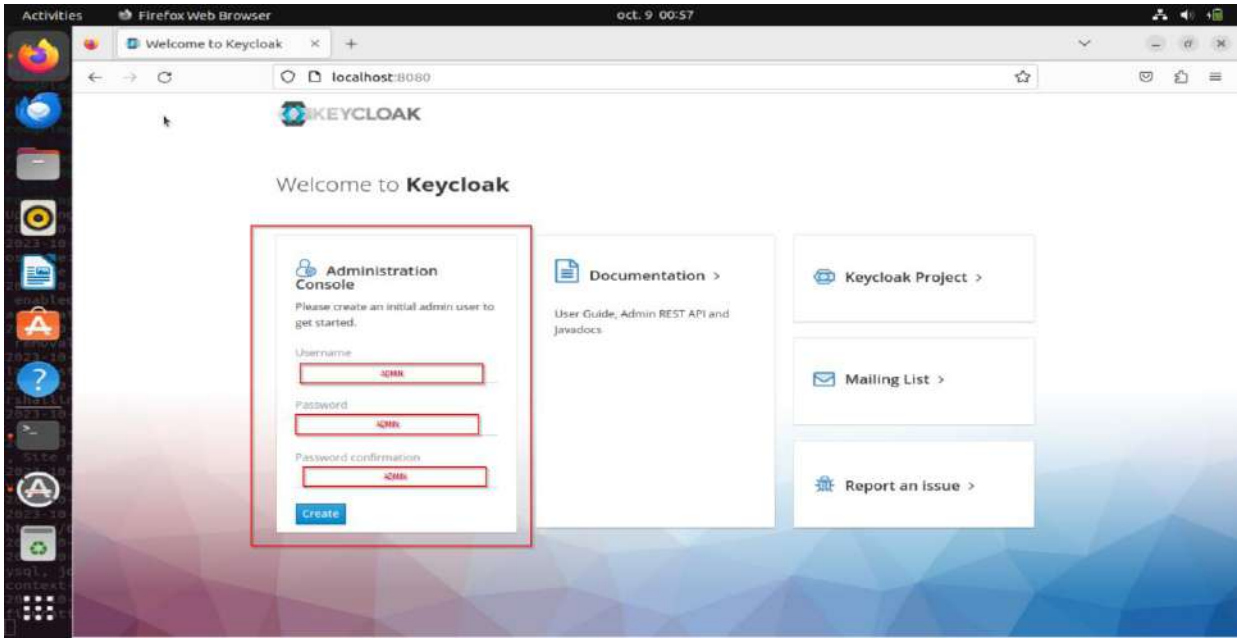
- Commencez par décompresser le dossier Keycloak.
- Ouvrez le menu et lancez un terminal.
- Accédez au répertoire décompressé de Keycloak avec la commande : `cd /Downloads/keycloak-22.0.4`
- Ensuite, entrez dans le répertoire bin avec la commande : `cd bin`
- Une fois dans le répertoire bin, pour déployer le serveur Keycloak, tapez la commande suivante : `./kc.sh start-dev`

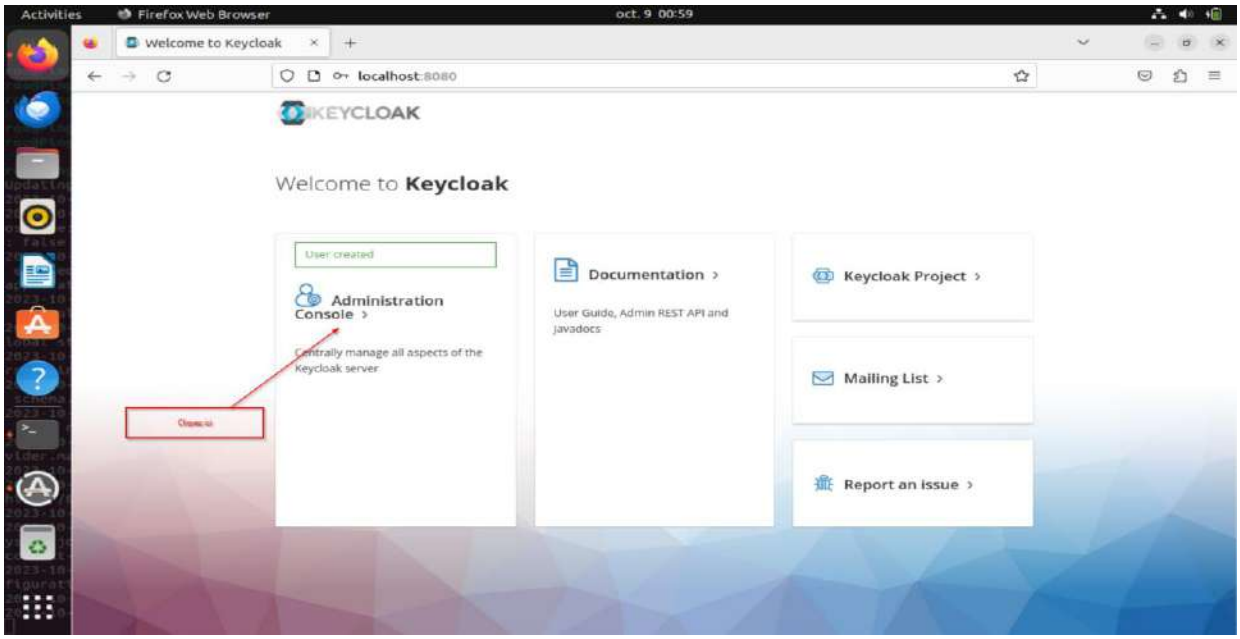


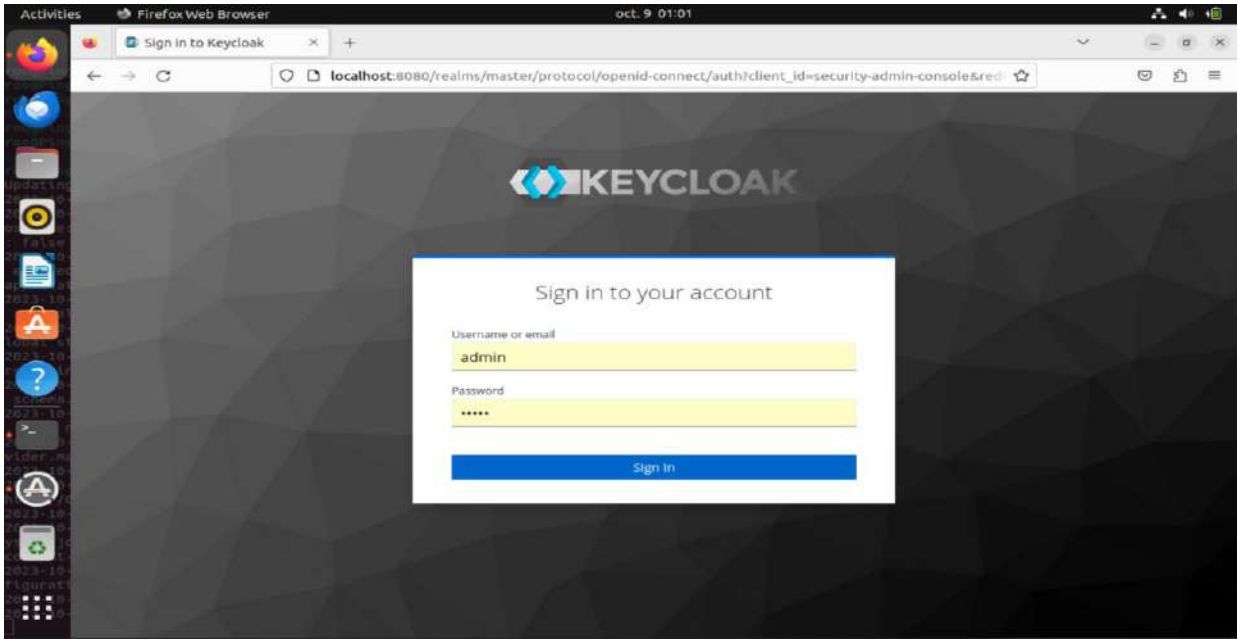
2. Configuration de base de Keycloak :

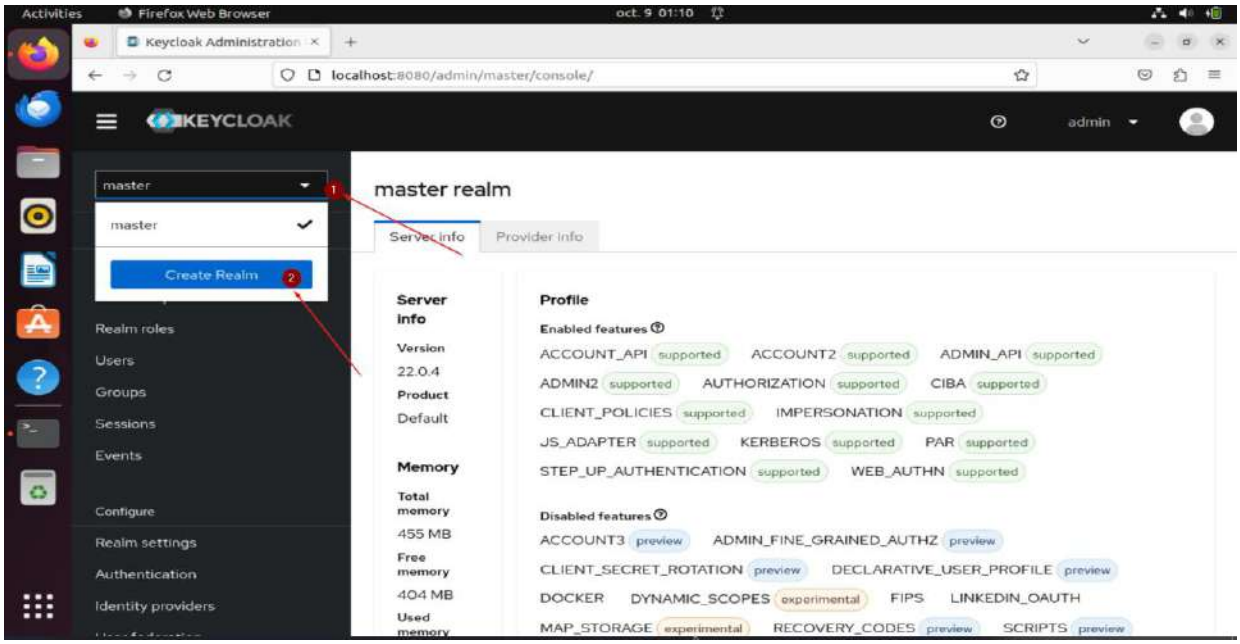
Pour configurer Keycloak, suivez les étapes ci-dessous :

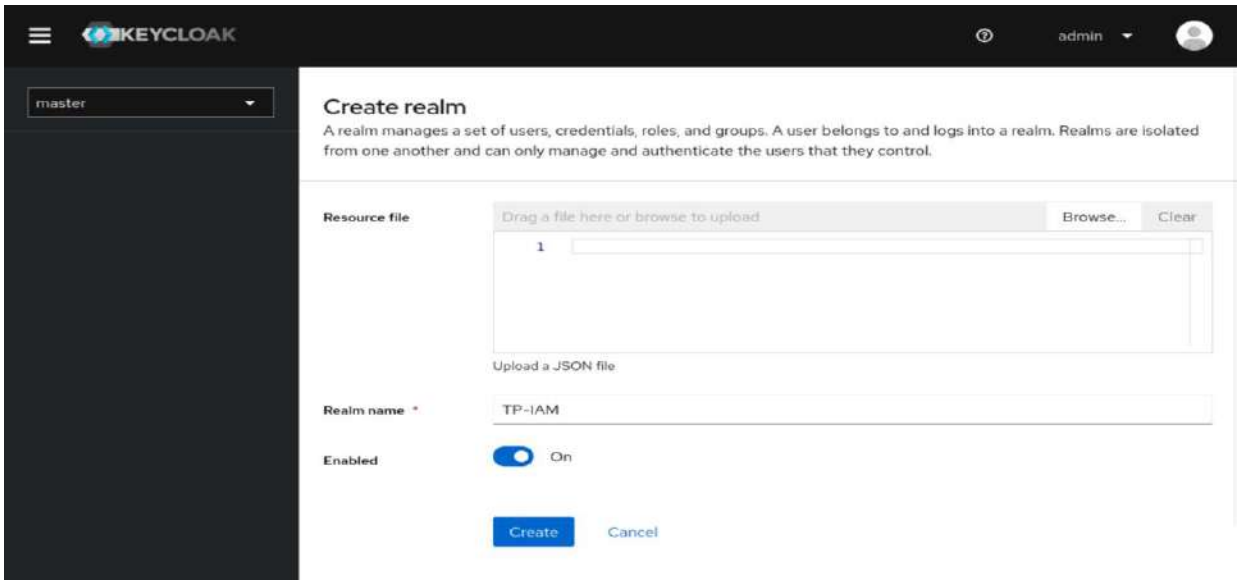
- Ouvrez un navigateur et accédez à l'interface d'administration de Keycloak via l'URL : `http://localhost:8080`
- Créez les identifiants d'administration. Par exemple : - Nom d'utilisateur : admin
  - Mot de passe : admin
- Cliquez ensuite sur "Administration Console" et connectez-vous avec les identifiants que vous venez de créer.
- Dans la barre de navigation, cliquez sur l'onglet "Realm" (généralement intitulé "master").
- Cliquez ensuite sur le bouton "Create Realm".
- Dans le champ prévu à cet effet, donnez un nom à votre realm.
- Pour finaliser la création, cliquez sur le bouton "Create".




Activities
Firefox Web Browser
oct. 9 00:59
Welcome to Keycloak
localhost:8080
KEYCLOAK
Welcome to Keycloak
User created
Administration Console
Centrally manage all aspects of the Keycloak server
Documentation
User Guide, Admin REST API and javadocs
Keycloak Project
Mailing List
Report an issue


Activities
Firefox Web Browser
oct. 9 01:01
Sign in to Keycloak
localhost:8080/realms/master/protocol/openid-connect/auth?client_id=security-admin-console&red
KEYCLOAK
Sign in to your account
Username or email
admin
Password
Sign In


Activities
Firefox Web Browser
oct. 9 01:10
Keycloak Administration
localhost:8080/admin/master/console/
KEYCLOAK
admin
master
master
Create Realm
Realm roles
Users
Groups
Sessions
Events
Configure
Realm settings
Authentication
Identity providers
master realm
Server info
Provider info
Server info
Version
22.0.4
Product
Default
Memory
Total memory
455 MB
Free memory
404 MB
Used memory
Profile
Enabled features
ACCOUNT_API supported
ACCOUNT2 supported
ADMIN_API supported
ADMIN2 supported
AUTHORIZATION supported
CIBA supported
CLIENT_POLICIES supported
IMPERSONATION supported
JS_ADAPTER supported
KERBEROS supported
PAR supported
STEP_UP_AUTHENTICATION supported
WEB_AUTHN supported
Disabled features
ACCOUNT3 preview
ADMIN_FINE_GRAINED_AUTHZ preview
CLIENT_SECRET_ROTATION preview
DECLARATIVE_USER_PROFILE preview
DOCKER
DYNAMIC_SCOPES experimental
FIPS
LINKEDIN_OAUTH
MAP_STORAGE experimental
RECOVERY_CODES preview
SCRIPTS preview


KEYCLOAK
admin
master
Create realm
A realm manages a set of users, credentials, roles, and groups. A user belongs to and logs into a realm. Realms are isolated from one another and can only manage and authenticate the users that they control.
Resource file
Drag a file here or browse to upload
Browse...
Clear
Upload a JSON file
Realm name *
TP-IAM
Enabled
On
Create
Cancel

3. Ajout d'utilisateurs dans Keycloak :

Créez un utilisateur "John Doe" dans Keycloak avec un mot de passe temporaire qui devra être modifié lors de sa première connexion.

- Testez la connexion en tant qu'utilisateur John Doe en vous rendant à l'adresse suivante : `http://localhost:8080/realms/TP-IAM/account/#/`

4. Configuration de l'OTP avec une application d'authentification OTP :

Configurez l'OTP pour l'utilisateur "john" dans Keycloak en utilisant une application d'authentification OTP sur votre téléphone. Assurez-vous de scanner le code QR fourni par Keycloak avec votre application d'authentification et de valider la configuration. Lors de la connexion, l'utilisateur "john" devra fournir le code OTP généré par l'application pour s'authentifier.

Test de l'authentification avec OTP :

- Déconnectez-vous de l'interface d'administration de Keycloak.
  Accédez à l'URL d'authentification de Keycloak, par exemple : `http://localhost:8080/realms/TP-IAM/account/#/`
- Connectez-vous avec les identifiants de l'utilisateur John Doe.
- Vous serez invité à entrer le code OTP généré par votre application OTP.
- Une fois le code OTP validé, vous serez connecté à l'interface de gestion du compte de l'utilisateur.

Félicitations ! Vous avez installé et configuré Keycloak avec la fonctionnalité OTP pour renforcer l'authentification des utilisateurs. Vous pouvez maintenant explorer davantage les fonctionnalités de gestion des identités et des accès offertes par Keycloak.

Exercice 2 : Mise en place du Single Sign-On (SSO) avec Keycloak Demo

Introduction :

- Keycloak app est une application de test fournie par Keycloak. Elle permet aux développeurs d'explorer et de tester les fonctionnalités de gestion des identités et des accès. Que ce soit pour le développement d'applications sécurisées, la formation ou les démonstrations, Keycloak app offre un environnement pratique pour comprendre et utiliser les fonctionnalités de Keycloak dans une application réelle.

Objectif :

- Dans cet exercice, nous allons utiliser Keycloak app pour mettre en place le Single Sign-On (SSO) entre différentes applications protégées par Keycloak. Le SSO permettra aux utilisateurs de se connecter à une application une seule fois et d'accéder à d'autres applications sans avoir à s'authentifier à chaque fois.

Étapes à suivre :

1. Accès à Keycloak Demo :

- Rendez-vous sur Keycloak app pour accéder à la démo.
  `https://www.keycloak.org/app`

2. Configuration des applications protégées :

- Ouvrez un navigateur web et accédez à l'URL de Keycloak, par exemple : http://localhost:8080
- Connectez-vous à la console d'administration en utilisant les informations d'identification de l'administrateur (nom d'utilisateur : admin, mot de passe : admin).
- Créez une nouvelle application cliente.
- Configurez les informations nécessaires
- Activez l'authentification et l'autorisation du client. Puis cliquez sur "Next".
- Configurez l'URL racine et les URIs de redirection valides

3. **Test du Single Sign-On (SSO) :**

   - Accédez à http://localhost:8080 avec le Realm TP-IAM et le Client myfirstclient.

   - Après vous être connecté à Keycloak, vous accéderez directement à l'application

Félicitations ! Vous avez mis en place le Single Sign-On (SSO) entre les applications protégées et Keycloak app. Les utilisateurs pourront maintenant se connecter une seule fois et accéder à différentes applications sans avoir à s'authentifier à chaque fois. N'hésitez pas à explorer d'autres fonctionnalités de Keycloak App pour gérer les autorisations, les rôles et les utilisateurs dans un environnement sécurisé.

Exercice 3 : Fédérer une application via le protocole OIDC et visualiser le contenudu token d'identité

Dans cet exercice, vous allez configurer Keycloak en tant que fournisseur OIDC (OpenID Connect) et fédérer une application en utilisant le protocole OIDC. L'objectif est de permettre à l'application de demander des informations d'identification à Keycloak et d'obtenir un token d'identité contenant les informations de l'utilisateur authentifié.

Contexte :

Lorsque vous utilisez une application en ligne, vous êtes souvent invité à vous connecter en utilisant un compte existant, par exemple votre compte Google ou Facebook. Ces comptes agissent en tant que fournisseurs d'identité, et l'application se connecte à ces derniers afin de vérifier votre identité.
Le protocole OIDC facilite cette interaction entre l'application et le fournisseur d'identité, permettant une authentification sécurisée et un échange d'informations d'identification.

Notions techniques :

1. OpenID Connect (OIDC) : C’est un protocole d'authentification basé sur OAuth 2.0 qui permet à une application de demander des informations d'identification à un fournisseur d'identité et de recevoir un token d'identité en retour.
2. Token d'identité : Un jeton émis par le fournisseur d'identité qui contient des informations sur l'identité de l'utilisateur authentifié. Ce token est utilisé par l'application pour vérifier l'identité de l'utilisateur et accéder aux ressources appropriées.

Voici les étapes à suivre pour cet exercice :

1. **Accéder à l'interface d'administration de Keycloak :**
   a. Ouvrez votre navigateur et accédez à l'URL de l'interface d'administration de Keycloak.
   b. Connectez-vous en utilisant les informations d'identification de l'administrateur.
   c. Rendez-vous dans le realm crée précédemment

2. **Créer un nouveau client pour l'application OIDC Debugger :**

3. **Obtenir les informations d'identification du client :**
   a. Recherchez "Authorization Endpoint". L'URL à côté de cette entrée est celle que vous devez utiliser pour OIDC Debugger. Gardez-là de côté.

4. **Accéder à l'application OIDC Debugger :**
   a. Ouvrez un nouvel onglet dans votre navigateur et accédez à l'URL de l'application OIDC Debugger (**https://oidcdebugger.com/**).

5. **Configurer l'application OIDC Debugger :**

   a. Saisissez l'URL d'autorisation de Keycloak dans le champ "Authorization Endpoint".
   b. Saisissez le "Client ID" que vous avez créé précédemment dans Keycloak pour l'application OIDC Debugger. (OIDC-DEBUG)
   c. Pour Response type sélectionnez token et pour response mode sélectionner fragment.
   d.Cliquez sur le bouton "SEND REQUEST" pour démarrer le processus d'authentification.

6. **Authentification avec Keycloak :**

   a. Vous serez redirigé vers la page d'authentification de Keycloak.
   b. Saisissez vos informations d'identification (nom d'utilisateur et mot de passe) pour vous connecter à Keycloak.
   c. Une fois authentifié, vous serez redirigé vers l'application OIDC Debugger.

7. **Visualiser le contenu du token d'identité :**

   a. Sur la page de l'application OIDC Debugger, recherchez la section "ID Token".
   b. Vous verrez le token d'identité qui a été généré par Keycloak.
   c. Ce token contient des informations sur l'identité de l'utilisateur authentifié, telles que son nom, son prénom, etc.